Daily Work Log — 29 October 2026

Workload Identity Inventory · Non-Human Identity (Step 8) · PowerShell Tooling · Key Vault Readiness · Password Reset

What was done today, why, and the evidence. Tenant ID, object IDs and the tenant domain are masked because this repository is public. The screenshots were captured on 2 November from read-only commands and the evidence files saved on 29 October.

Project	Healthcare IAM Operations Simulation — Horizon Valley Medical Center (HVMC)
Environment	Microsoft Entra ID (Free tier, security defaults on) · HVMC PKI (Issuing CA 1) · GitHub repository dae-6-month-Sabi
Prepared By	Sabitha S Karanavar
Date	October 29, 2026
Cost	$0 — Entra ID Free features only; the Azure subscription was checked, not used

Summary of the day

#	Work	Reference	Result
1	Inventory of service accounts and workload identities; notes saved for the next access review	HVMC-AR-2027-Q1 · commit 15ca6ad	**Done, pushed**
2	First non-human identity “HVMC Lab Results Sync”: certificate from the HVMC PKI, one read-only permission, least-privilege test	HVMC-IAM-CHG-108 · finding F8 · commit c8109b4	**Done, 3/3 tests passed**
3	PowerShell 7.6.9 and seven Microsoft Graph modules installed without admin rights	—	**Done**
4	Azure Key Vault approved by the instructor; subscription checked and options prepared	—	Waiting on subscription choice
5	All 30 staff passwords from the bulk-create file reset; file deleted; new list in a protected archive	HVMC-IAM-CHG-109 · finding F9	**Done, 30/30**
6	Checked that adding the NHI changed none of the earlier documents or the PKI	—	**No impact found**

1. Service accounts and workload identities

Why. Before creating a new non-human identity (NHI), I needed to know which ones already existed. In hospitals, forgotten service accounts with old passwords are a common way attackers get in.

What I found. No user accounts are being used as service accounts. The 11 HVMC applications have no secrets, certificates or API permissions, so they cannot sign in on their own. Two managed identities were created by Microsoft Defender for Storage during the SecOps lab and are probably orphaned now that the subscription is disabled. These findings are saved in the preparation notes for access review **HVMC-AR-2027-Q1** (January 2027).

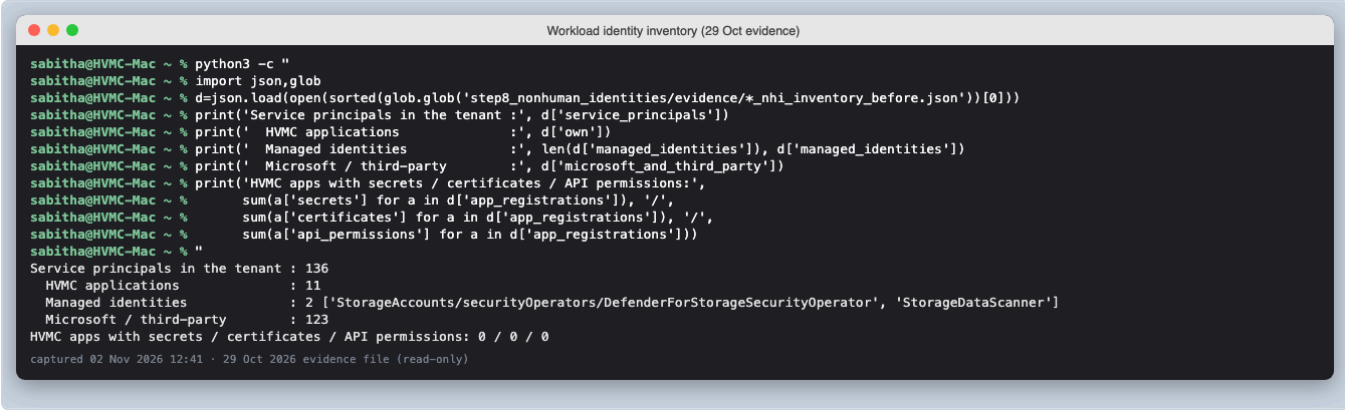


Figure 1. The read-only inventory saved before Step 8: 136 service principals, 11 HVMC apps with no credentials or permissions, 2 managed identities.

2. Step 8 — Non-human identity (HVMC-IAM-CHG-108, finding F8)

Why. Hospital systems exchange data without a person signing in, for example a lab interface reading who belongs to the lab groups. The project had no safe, governed pattern for this (finding F8).

How. The script `step8_nonhuman_identities/nhi.py` ran a dry run, then applied the change:

Control	How it was done
Owner and purpose	Technical owner: IAM administrator. Business owner: Laboratory lead. Recorded in the NHI register
No password or secret	Signs in with an X.509 certificate issued by **HVMC Issuing CA 1**, the PKI built for the Public Key Cryptography rubric
Private key protected	Stored locally with owner-only access (0600), never in Git; planned to move into Azure Key Vault
Least privilege	One permission only: Microsoft Graph **GroupMember.Read.All** (read group members)
Expiry	Certificate expires 29 Oct 2027; rotate by 29 Sep 2027; reviewed in HVMC-AR-2027-Q1

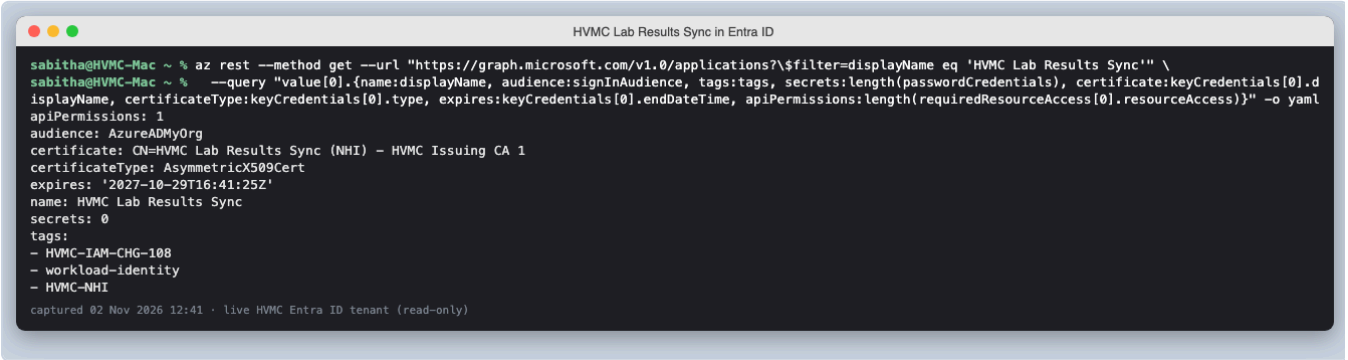


Figure 2. The application in Entra ID: single tenant, 0 secrets, 1 certificate from HVMC Issuing CA 1, 1 API permission, tagged with the change ticket.

Test. The NHI signed in as itself with its certificate and tried three things. It could do the one thing it needs and nothing else:

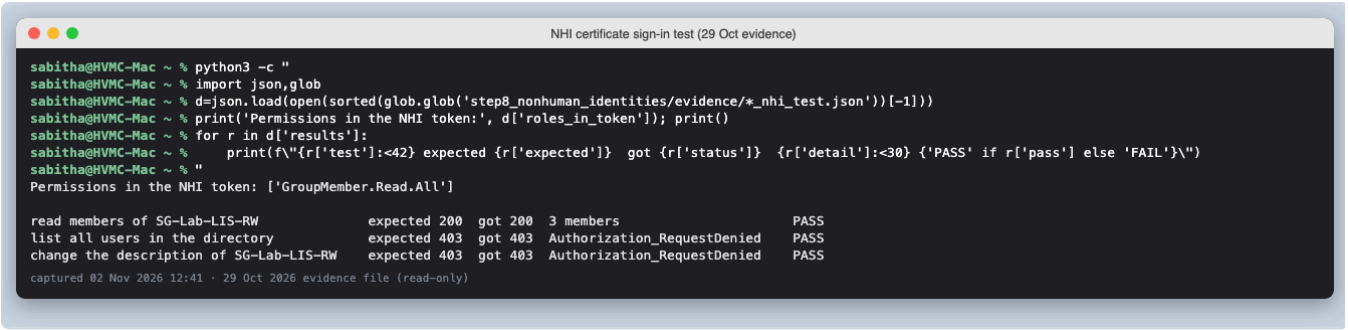


Figure 3. Least-privilege test: reading lab group members allowed (200); listing all users and changing a group denied (403). All three PASS.

Impact check. I confirmed that adding the NHI changed none of the earlier work. The PKI files and the cryptography reports are unchanged, because the CA key was only read to sign the certificate. In the IAM

report, section 10 was added and only the version, subtitle and next steps were updated.

3. PowerShell tooling

Why. The joiner/mover/leaver changes on 20 October were run by hand, one event at a time. Automating them is the next step (Step 8b), and PowerShell with the Microsoft Graph SDK is the standard tool for this in Microsoft shops.

How. The office Mac has no admin rights, so PowerShell 7.6.9 was installed in my user folder. I checked its download against Microsoft's SHA-256 hash and signature first. Only the seven Graph modules the project needs were installed, not the full 40-module bundle.

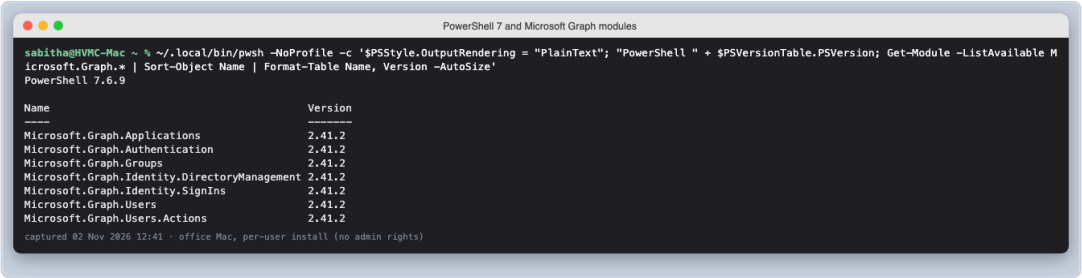


Figure 4. PowerShell 7.6.9 with seven Microsoft Graph modules (v2.41.2), installed for the current user only.

4. Azure Key Vault readiness

My instructor approved adding **Azure Key Vault**, so the NHI private key can live in a managed vault instead of on my laptop. A check showed the free trial subscription has been **disabled since 17 October**, so nothing can be created yet. If the old subscription were upgraded, the leftover resources from earlier labs (Bastion, NAT gateway, Sentinel and others) would cost about $200+ a month, so they would have to be deleted first.

Option	Cost	Status
A. Azure for Students, in the same HVMC tenant (recommended)	$0, $100 credit, no card	Waiting on my choice
B. Pay-As-You-Go after deleting the leftovers	Pay per use; Key Vault costs cents	Waiting on my choice
C. Design only, no Azure	$0	Fallback

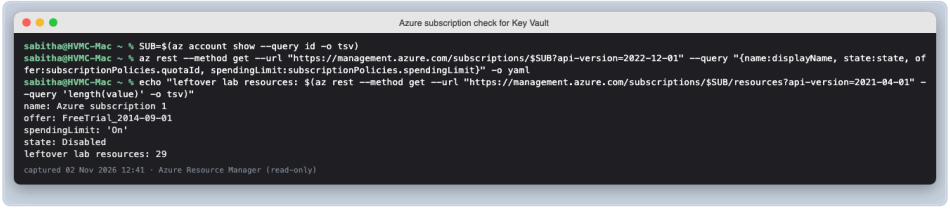


Figure 5. Read-only check: the free trial subscription is Disabled with the spending limit on, so it cannot bill; 29 leftover resources remain (re-counted 2 Nov).

5. Password reset (HVMC-IAM-CHG-109, finding F9)

Why. The 30 staff accounts were created from a CSV file that held every initial password in plain text. One of those passwords had been shown on screen in an earlier session. Anyone with a copy of the file could have signed in as any staff member.

How. The script `step9_credential_cleanup/password_reset.py` ran a dry run first: 30 accounts were found, none with an admin role, and one disabled leaver. It then gave every account a new random 16-character password. The passwords were never displayed and went straight into a password-protected archive. The archive was tested, and only then was the old file deleted.

> **Lab trade-off:** the new passwords are not forced to change at next sign-in, so I can still sign in as test staff. In a real hospital each person would get a one-time password or a Temporary Access Pass. The archive never leaves my workstation.

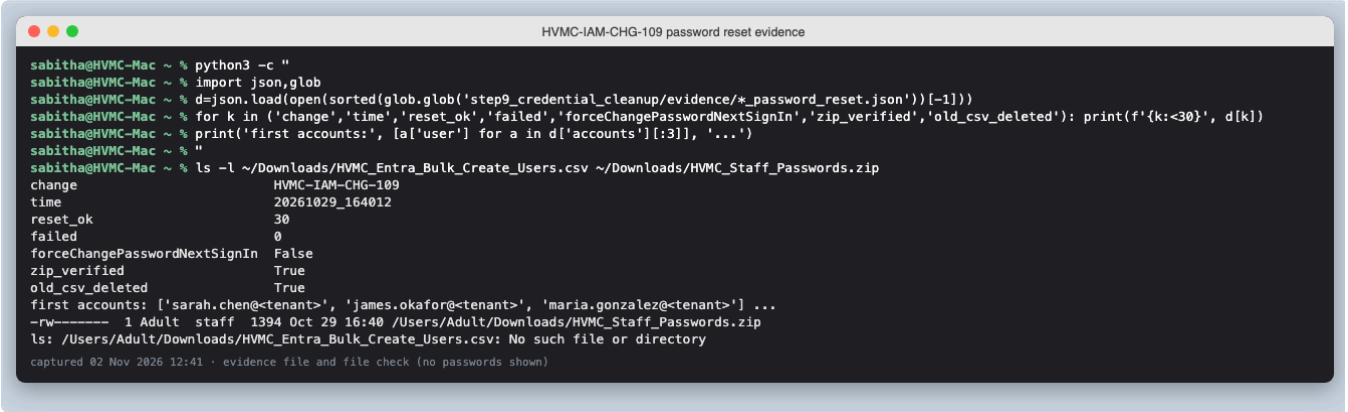


Figure 6. Reset evidence: 30 reset, 0 failed, archive verified, old file deleted. The evidence holds masked user names and no passwords.

The reset was added to the IAM report as Step 9 (version 1.3) on 2 November, in commit e92e3f8.

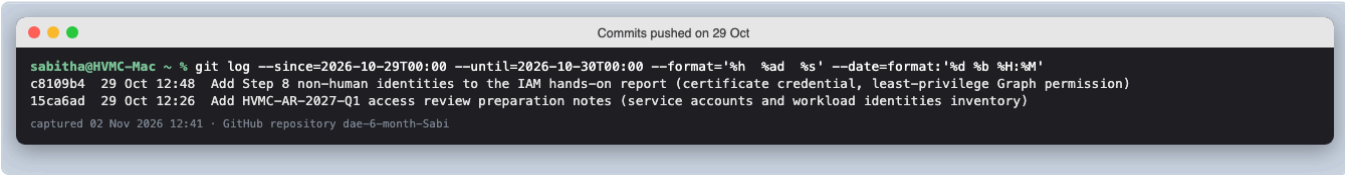


Figure 7. The two commits pushed on 29 October.

6. What I learned

- **Applications are identities too.** They need an owner, an expiry date and the smallest permission that works, just like staff accounts.
- **Certificates beat secrets.** A certificate from my own CA can be checked, given an expiry date and revoked. A client secret is just a password that is easy to copy.
- **Test that access is denied, not only allowed.** The two 403 results prove least privilege; a single 200 would not.

- **Setup files become secrets.** A CSV used once to create accounts kept working passwords for everyone until it was cleaned up.
- **Check the cost before you build.** A disabled subscription still holds resources that would bill if re-enabled.

7. Next steps

Action	When
Choose the Azure subscription option for Key Vault	Next
Move the NHI private key into Key Vault and add a managed identity	After the subscription
Lifecycle automation in PowerShell (Step 8b): joiner/mover/leaver tool and a daily leaver check	Next
Regenerate the SerpAPI key at serpapi.com	As soon as possible
Quarterly break-glass sign-in test	About 28 Jan 2027
Access review HVMC-AR-2027-Q1, including the NHI and the two Defender identities	January 2027